

Aura File Defender: Endpoint-Local Canonical Reconstruction of Media Attachments in End-to-End Encrypted Messaging

Oleksandr Melnychenko *

Khmelnyskyi National University, Khmelnytskyi, Ukraine

Abstract

End-to-end encryption protects attachment confidentiality in transit but does not determine whether decrypted media should be opened at an endpoint. This paper presents AURA FILE DEFENDER, an endpoint-local reconstruction and validation method for media attachments. The method places the same decision boundary before outgoing encryption and after incoming decryption, so the relay neither sees plaintext nor decides acceptance. A file is deliverable only when its portable name, caller-supplied media type, byte-derived format profile, required reconstruction level, and independently parsed canonical output converge. Structural and semantic reconstruction are distinguished explicitly, and a policy that requires semantic processing cannot fall back to copied codec payloads. Complete output consumption prevents trailing-object acceptance, while non-media, ambiguous, malformed, over-budget, and non-clean results expose no deliverable bytes. The evaluation protocol separates carrier-level malware properties from behavioral malware classification and preregisters corpus, differential-parser, fault-injection, fuzzing, fidelity, and performance gates. Empirical values are withheld from this drafting version until a pinned server run satisfies the complete machine-readable release gate.

Keywords: content disarm and reconstruction, end-to-end encryption, canonical parsing, media security, polyglot files, malware carriers

*Corresponding author.

Email address: melnychenko@khnmu.edu.ua (Oleksandr Melnychenko )

1. Introduction

Encrypted messaging changes where attachment inspection can occur. A relay that is not permitted to decrypt an attachment cannot reconstruct its content, whereas an endpoint that opens the decrypted object inherits the parser and decoder attack surface. Transport confidentiality and file admissibility are therefore separate security decisions. The first protects bytes in transit. The second determines which representation, if any, may reach a renderer. This distinction complements established secure-messaging models, which analyze communication confidentiality and key evolution but do not certify the safety of a decrypted attachment representation [1, 2].

Conventional scanning and content reconstruction are often described as gateway services. That placement does not preserve the confidentiality model of a protected conversation. It also encourages a binary interpretation in which a file is either labelled malicious or passed through. Media reconstruction supports a narrower and testable statement: an accepted output belongs to a constrained grammar and was derived at the reconstruction strength required by policy. This statement does not imply that retained pixels or audio samples are semantically harmless.

The research question is whether endpoint-local reconstruction can preserve a blind relay while establishing a reproducible, format-specific acceptance boundary for attachments. The contribution is a composed method rather than a new codec. It combines concrete input-profile convergence, an explicit reconstruction-strength order, independent complete output parsing, fail-closed publication, and a preregistered evidence protocol. These elements are evaluated as separate claims so that a successful parser test is not presented as malware detection and a successful decode is not presented as canonical validation.

2. Related Work and Claim Boundary

File-processing discrepancies are an established evasion surface. Jana and Shmatikov showed that disagreements between detector-side and host-side format interpretation can permit malware to evade analysis without changing its executable behavior [3]. Language-theoretic security consequently treats accepted input as a language that should be specified explicitly and recognized before use [4]. Nail operationalizes a related idea by deriving parsers and generators from one grammar [5]. EverParse adds machine-checked safety, inverse parsing and serialization, and unique representations

for authenticated message formats [6]. Interval parsing grammars address random-access and type-length-value dependencies that arise in binary file formats [7]. These systems motivate grammar-centred validation, but they do not define an attachment publication policy for protected messaging endpoints.

Polyglot research demonstrates why a leading signature or one successful decoder is insufficient. Albertini et al. systematize format combinations in the different setting of authenticated encryption without key commitment [8]. Koch et al. document polyglot attack chains, evaluate format identification, and present an image sanitization tool [9]. You et al. show that even implementations nominally parsing the same ZIP format can disagree at the semantic level [10]. These findings support differential validation and complete-consumption checks. They do not justify treating any single detector as an oracle.

The contribution here is neither a new media codec nor a universal malware classifier. It is an enforcement composition whose deployment point and acceptance rule are jointly specified. The method places reconstruction at both ends of a blind encrypted relay. It requires name, declared media type, and byte evidence to converge on a concrete profile before dispatch. It then requires the performed reconstruction strength and a separate complete parser to agree before any bytes can be published. The evaluation binds each of these claims to a distinct machine-readable gate rather than inferring security from aggregate scanner accuracy.

The behavioral terms used in Table 1 follow the conventional malware categories summarized by NIST [11]. The measured properties remain narrower. They concern carrier grammar, embedded active objects, metadata, and reconstruction outcome rather than program behavior after execution.

3. System and Adversary Model

The adversary controls attachment bytes, display name, declared media type, container metadata, dimensions, counts, offsets, codec payload, and request frequency. The policy, authenticated application binary, and local publication directory are trusted. External decoders are trusted only within the stated process-isolation assumptions. Compromise of the endpoint before processing and harmful semantic content visible in a legitimate raster or waveform are outside the attachment-reconstruction claim.

Table 1: Permitted interpretation of malware terminology in the evaluation.

Behavioral label	Measured attachment property	Permitted conclusion
File-infecter virus	Executable prefix, modified host grammar, or appended executable body	Carrier rejected by type, grammar, or polyglot policy
Worm or downloader	Script, executable, shortcut, package, or active document	Unsupported active carrier rejected
Trojan	Executable or script presented with media evidence	Classifier disagreement or unsupported grammar rejected
Ransomware or spyware	Executable carrier or specified privacy metadata	Carrier rejected or named metadata removed
Exploit-bearing media	Reproducible malformed structure or decoder regression	Frozen path rejected or reconstructed this sample
Steganographic payload	Information retained in pixels or samples	Outside the reconstruction claim

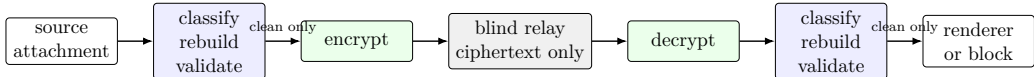


Figure 1: Symmetric endpoint placement of the reconstruction boundary. The relay transports ciphertext and does not authorize attachment delivery.

4. Canonical Reconstruction Method

Let x denote input bytes, n a display name, m a caller-supplied media type, and p a policy. Three independent functions derive concrete format profiles from the final extension, parsed media type, and bounded byte evidence. The media type is not treated as ground truth. HTTP semantics likewise warn that media-type sniffing can create security risks and that byte inspection cannot determine every processing model [12]:

$$e(x, n, m) = (E(n), M(m), B(x)). \quad (1)$$

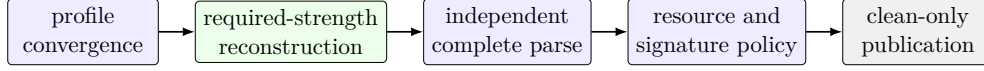


Figure 2: Conjunctive acceptance path. Failure or uncertainty at any stage produces no deliverable bytes. No stage can authorize publication alone.

Aliases are represented explicitly. Compatibility does not collapse distinct grammars merely because they belong to the same top-level media family.

Definition 4.1 (Reconstruction strength). *The performed strength belongs to $\{\text{Unprocessed}, \text{Structural}, \text{Semantic}\}$ with*

$$\text{Unprocessed} \prec \text{Structural} \prec \text{Semantic}. \quad (2)$$

Structural reconstruction emits a newly parsed container but may retain codec payload. Semantic reconstruction decodes media state and encodes a new object.

For candidate output $y = \text{Rebuild}_{p,k}(x)$, an independent parser returns a profile, component count, and terminal offset. Delivery is authorized by the conjunction

$$\begin{aligned} \text{Accept}(p, x, n, m, y, k) = & N_p(n) \wedge C_p(e, k) \wedge L_p(k) \\ & \wedge \text{Parse}_k(y) \wedge T_k(y) = |y| \\ & \wedge K_p(k, y) \wedge S_p(y) \wedge Q_p(x, y), \end{aligned} \quad (3)$$

where N_p is portable-name acceptance, C_p is profile convergence, L_p is reconstruction-level satisfaction, K_p is canonical component closure, S_p is the post-reconstruction signature policy, and Q_p contains resource bounds. No single classifier or decoder exit status can satisfy Equation (3).

Property 4.2 (Fail-closed publication). *For every result r ,*

$$\text{Deliver}(r) = 1 \iff r.\text{verdict} = \text{Clean}. \quad (4)$$

Both Suspicious and Blocked carry zero deliverable bytes. Filesystem publication is separated from reconstruction and occurs only through a same-directory temporary file after a complete write.

5. Format Profiles and Polyglot Handling

The output language is an allowlist of registered canonical grammars. Each parser starts at offset zero, rejects budget exhaustion as failure, and reports complete consumption. Prefix camouflage, appended grammar, overlapping grammar, and nested active objects are measured separately. Semantic neutralization is claimed only when no source container or compressed payload bytes are copied into the output and the new representation passes an independent complete parser. Normative format rules supply the lower-level closure conditions. For example, the PNG specification fixes signature, chunk, and terminal-IEND requirements [13], while the Ogg Opus specification defines mandatory headers and page organization [14].

6. Implementation

The reference implementation is a Rust workspace with separate policy, signature, observability, foreign-function, media-handler, and facade crates. Input-profile convergence precedes handler dispatch. Every handler reports the performed reconstruction strength and exact structural removal counters where the parser can identify source regions. Output acceptance uses a separate validator module rather than trusting a handler declaration.

Animated WebP is routed separately from static WebP. Its structural handler removes ICC, EXIF, and XMP chunks, bounds canvas and frame work, and retains constrained compressed frame payloads. The independent validator reparses the complete RIFF object and decodes every frame, but the performed level remains structural because the frame payloads are not regenerated. For ISO BMFF audio, `audio/mp4`, `audio/x-m4a`, and `audio/m4a` converge on one profile. The rewriter removes excluded Apple advisory atoms before the same complete sample-table and media-extent validation used for other MP4 outputs.

External FFmpeg and FFprobe work is supervised with a wall-clock deadline, cancellation token, bounded diagnostics, output-file monitoring, and process termination on all exit paths. Linux execution adds a dedicated process group, no-new-privileges state, disabled core dumps, CPU and output-file limits, and a bounded address space. The C and Swift boundaries repeat the clean-only output invariant. The Apple artifact contains iOS, Simulator, Mac Catalyst, and macOS slices built from one locked source revision. Its build remaps local source paths, fixes archive epochs, and canonically serializes the XCFramework property list before distribution comparison.

Table 2: Release treatment by media family. Exact accepted profiles are frozen in the machine-readable registry.

Family	Principal transformation	Acceptance boundary
PNG, JPEG, static WebP	Pixel decode and re-encode	Complete canonical raster parse and decode
GIF	Frame decode and re-encode	Canvas, frame, timing, trailer, and complete sub-block parse
APNG	Bounded chunk reconstruction	Structural profiles only.
Animated WebP	Bounded RIFF and frame reconstruction	Semantic-required profiles block Metadata-free structural profile, complete frame parse and decode.
MP3, WAV, FLAC	Metadata-aware structural reconstruction or transcode	Semantic-required profiles block Complete frame/chunk grammar and integrity fields
Ogg/Opus	Page and packet reconstruction or transcode	CRC, sequence, packet, codec, and EOS closure
MP4/M4A	Parent-aware atom reconstruction or transcode	Media-type alias convergence, Apple advisory-atom removal, track and sample-table closure
WebM	Nested EBML reconstruction or transcode	DocType, track, block, lacing, timestamp, and boundary closure
Other formats	No pass-through	Non-media and unsupported classes block

7. Evaluation Protocol

The corpus is stratified into canonical benign media, benign noncanonical media, malformed structures, classifier disagreement, polyglot carriers, resource-exhaustion cases, unsupported active classes, and decoder regressions. Ground truth requires a reproducible generator, two independent reference parsers, or documented adjudication by at least two reviewers. Every accepted output is saved by digest and checked by independent parser fami-

Table 3: Controlled-run summary. Values remain pending until the run manifest reports a passed scientific release gate.

Run identifier	pending
Source commit	pending
Corpus samples	pending
Clean / non-clean outcomes	pending / pending
False-blocking rate	pending
Median / p95 latency	pending / pending
Peak resident memory	pending
Fuzzing budget	pending
Fidelity summary	pending

lies.

For deterministic structural or lossless paths, stability requires

$$\text{Rebuild}_{p,k}(\text{Rebuild}_{p,k}(x)) = \text{Rebuild}_{p,k}(x). \quad (5)$$

Lossy semantic paths use the weaker named property of canonical closure and are evaluated with separately frozen fidelity thresholds. Performance observations are grouped by format and reconstruction level. Confidence intervals use a hierarchical bootstrap over server sessions and corpus samples, while corpus order is deterministically permuted for each session.

8. Discussion and Limitations

Canonical reconstruction narrows the representation delivered to a renderer. It does not prove the absence of malicious meaning or information encoded in retained semantic content. Structural reconstruction cannot claim removal of a payload inside copied codec frames. Semantic reconstruction depends on the decoder, encoder, operating-system isolation, and the fidelity thresholds used in the evaluation. Coverage-guided fuzzing and parser agreement are empirical evidence rather than a proof of parser correctness.

The method also makes an explicit availability trade-off. Unknown formats, missing evidence, and unavailable required tools are non-deliverable under the release profile. The false-blocking analysis must therefore be reported by concrete format and corpus stratum rather than hidden in one aggregate rate. Future work may add a semantic animated-WebP path, stronger operating-system sandboxing for external decoders, and typed export of all parser resource counters.

9. Conclusion

AURA FILE DEFENDER treats attachment admissibility as an endpoint-local, format-specific decision that remains compatible with a blind encrypted relay. Its central claim is not universal malware detection. It is the enforceable conjunction of profile convergence, required reconstruction strength, complete canonical output parsing, bounded execution, and clean-only publication. The frozen evaluation protocol is designed to show precisely which part of that conjunction is supported by each experiment.

Data and Code Availability

The source revision, policy, classifier registry, corpus manifest, raw observations, analysis scripts, tool digests, and run-manifest hashes will be reported with the evaluated artifact. Raw malicious samples that cannot be redistributed will remain in the isolated corpus and will be represented by provenance, mutation recipes, and cryptographic digests.

References

- [1] N. Unger, S. Dechand, J. Bonneau, S. Fahl, H. Perl, I. Goldberg, and M. Smith, “SoK: Secure Messaging,” in *2015 IEEE Symposium on Security and Privacy*, 2015, pp. 232–249. <https://doi.org/10.1109/SP.2015.22>
- [2] K. Cohn-Gordon, C. Cremers, B. Dowling, L. Garratt, and D. Stebila, “A formal security analysis of the Signal messaging protocol,” *Journal of Cryptology*, vol. 33, pp. 1914–1983, 2020. <https://doi.org/10.1007/s00145-020-09360-1>
- [3] S. Jana and V. Shmatikov, “Abusing file processing in malware detectors for fun and profit,” in *2012 IEEE Symposium on Security and Privacy*, 2012, pp. 80–94. <https://doi.org/10.1109/SP.2012.15>
- [4] F. Momot, S. Bratus, S. M. Hallberg, and M. L. Patterson, “The seven turrets of Babel: A taxonomy of LangSec errors and how to expunge them,” in *2016 IEEE Cybersecurity Development*, 2016, pp. 45–52. <https://doi.org/10.1109/SecDev.2016.019>
- [5] J. Bangert and N. Zeldovich, “Nail: A practical tool for parsing and generating data formats,” in *11th USENIX Symposium on Operating Systems Design and Implementation*, 2014, pp. 615–628. <https://www.usenix.org/conference/osdi14/technical-sessions/presentation/bangert>

- [6] T. Ramananandro, A. Delignat-Lavaud, C. Fournet, N. Swamy, T. Chajed, N. Kobeissi, and J. Protzenko, “EverParse: Verified secure zero-copy parsers for authenticated message formats,” in *28th USENIX Security Symposium*, 2019, pp. 1465–1482. <https://www.usenix.org/conference/usenixsecurity19/presentation/delignat-lavaud>
- [7] J. Zhang, G. Morrisett, and G. Tan, “Interval parsing grammars for file format parsing,” *Proceedings of the ACM on Programming Languages*, vol. 7, no. PLDI, art. 150, 2023. <https://doi.org/10.1145/3591264>
- [8] A. Albertini, T. Duong, S. Gueron, S. Kölbl, A. Luykx, and S. Schmieg, “How to abuse and fix authenticated encryption without key commitment,” in *31st USENIX Security Symposium*, 2022, pp. 3291–3308. <https://www.usenix.org/conference/usenixsecurity22/presentation/albertini>
- [9] L. Koch, S. Oesch, A. Sadovnik, B. Weber, A. Chaulagain, M. Dixon, J. Dixon, M. Huettel, C. Watson, J. Hartman, and R. Patulski, “On the abuse and detection of polyglot files,” in *Proceedings of the ACM Web Conference 2025*, 2025, pp. 4810–4822. <https://doi.org/10.1145/3696410.3714814>
- [10] Y. You, J. Chen, Q. Wang, and H. Duan, “My ZIP isn’t your ZIP: Identifying and exploiting semantic gaps between ZIP parsers,” in *34th USENIX Security Symposium*, 2025, pp. 431–450. <https://www.usenix.org/conference/usenixsecurity25/presentation/you>
- [11] M. Souppaya and K. Scarfone, *Guide to Malware Incident Prevention and Handling for Desktops and Laptops*, NIST Special Publication 800-83 Revision 1, 2013. <https://doi.org/10.6028/NIST.SP.800-83r1>
- [12] R. Fielding, M. Nottingham, and J. Reschke, *HTTP Semantics*, RFC 9110, 2022. <https://www.rfc-editor.org/rfc/rfc9110>
- [13] W3C PNG Working Group, *Portable Network Graphics (PNG) Specification, Third Edition*, W3C Recommendation, 2025. <https://www.w3.org/TR/png-3/>
- [14] T. Terriberry, R. Lee, and R. Giles, *Ogg Encapsulation for the Opus Audio Codec*, RFC 7845, 2016. <https://www.rfc-editor.org/rfc/rfc7845>